



ISC 互联网安全大会



360 互联网安全中心

新常态下的安全新思维

薛忠胜

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China



ISC 互联网安全大会



360 互联网安全中心

目录

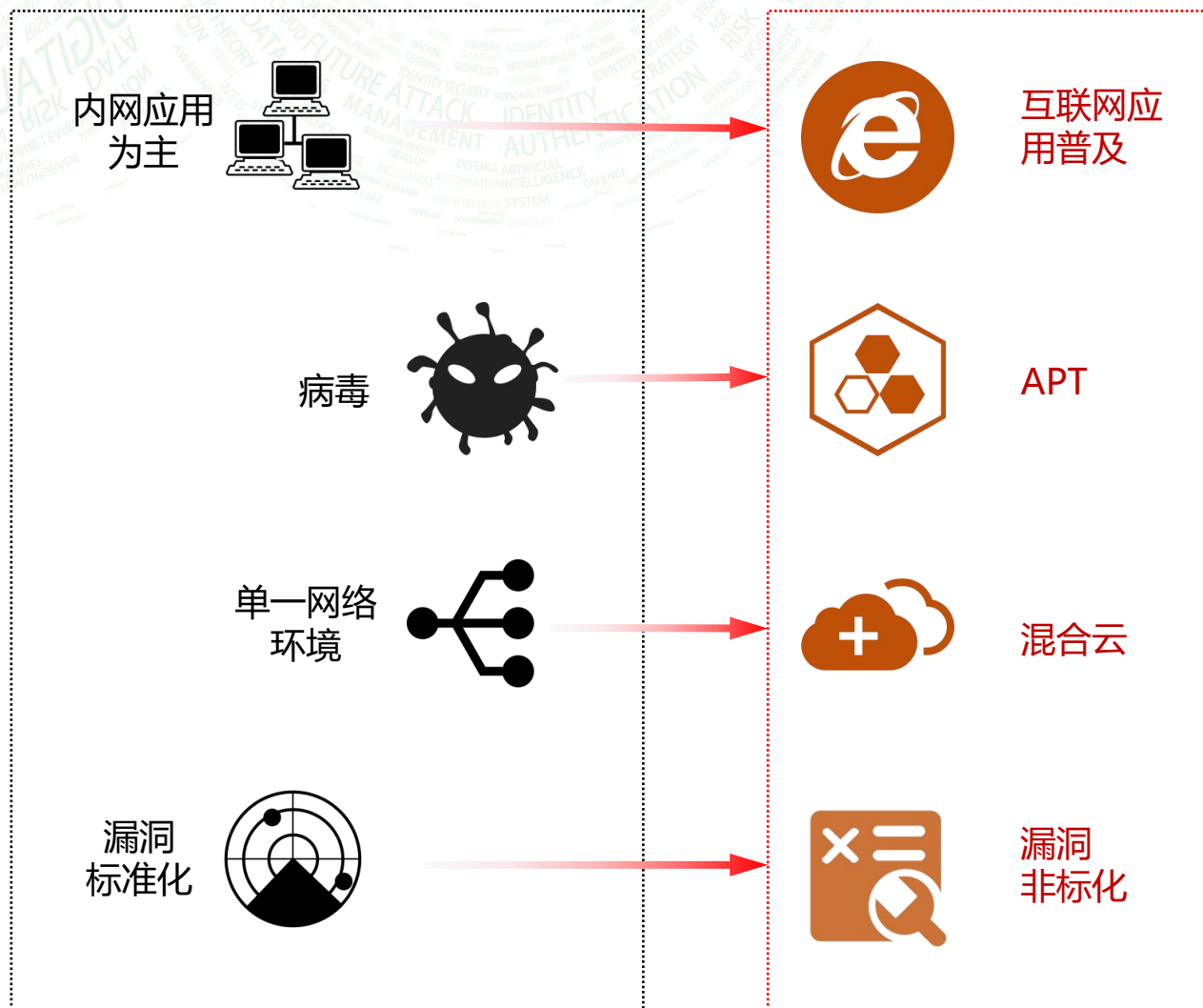
1 / 互联网背景下的安全新常态

2 / 企业网络安全管理的新思维

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

1.1 网络安全内外部环境和威胁越来越复杂，形势越来越严峻



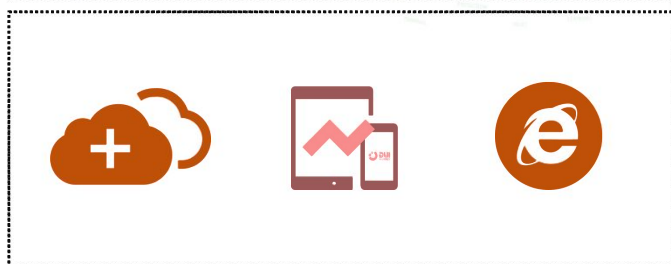
- 持续互联网化，使我们的攻击面不断扩大
- 攻击类型越来越多，攻击方法传播更快
- 软件定义一切，网络边界逐渐消融
- 非标准化弱点成为企业安全问题的主流

ZERO TRUST SECURITY

1.2 企业面临的网络安全管理越来越困难，责任越来越大



(1) 面临多种攻击，单纯的防御正逐渐失效



(2) 网络边界消融，传统安全控制点逐渐消失



(3) 业务发展迅速，传统安全理念不再适用



(4) 监管要求更高，稍有不慎便导致合规风险

1.3 网络安全管理新理念

安全理念的转变





ISC 互联网安全大会



360 互联网安全中心

目录

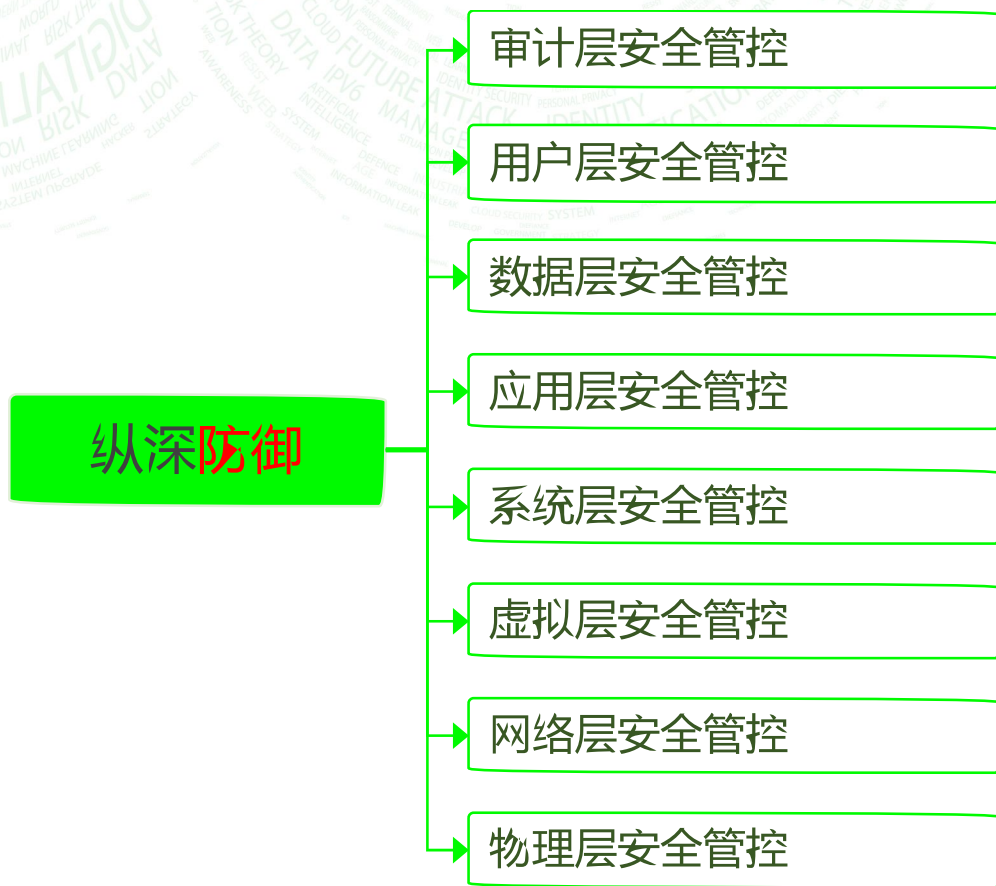
1 / 互联网背景下的安全新常态

2 / 企业网络安全管理的新思维

ZERO TRUST SECURITY

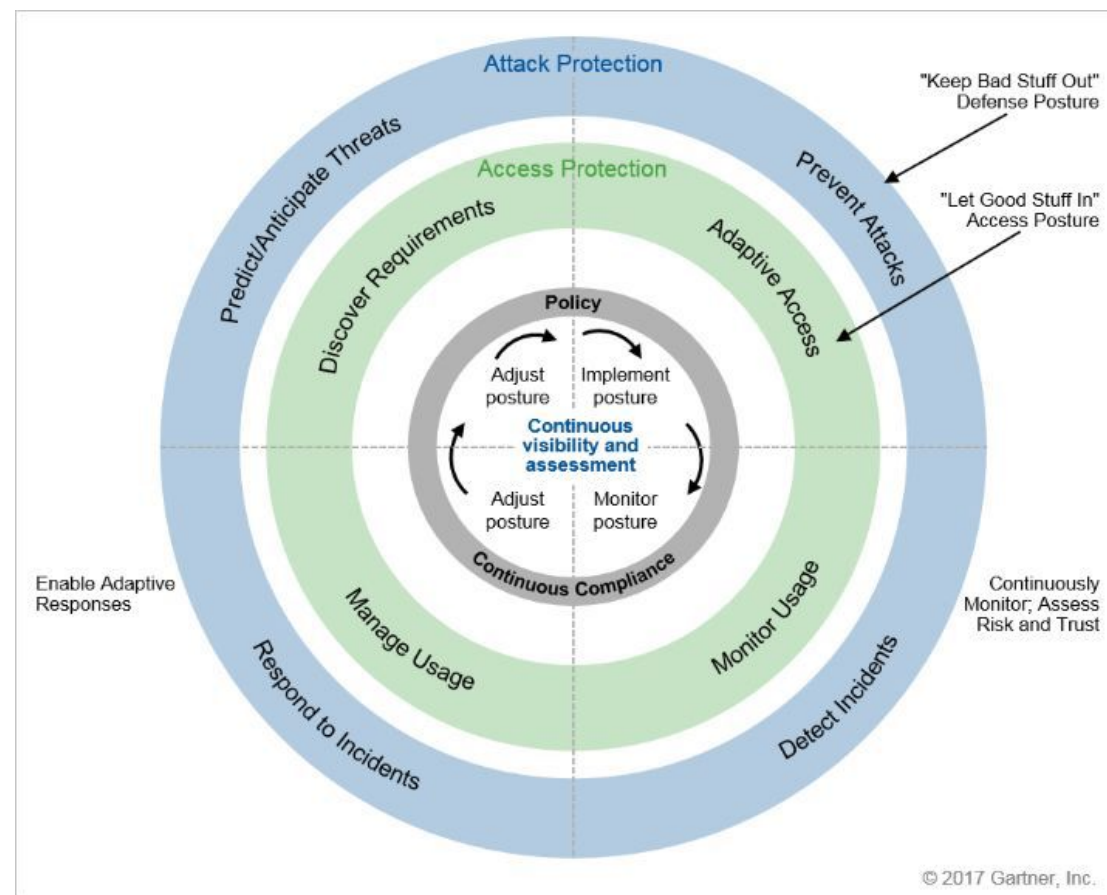
WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL AUTOMATION

2.1 调整单纯的防御思路，转而为以预测、检测、防御和响应一体的安全架构



【传统安全防御架构】

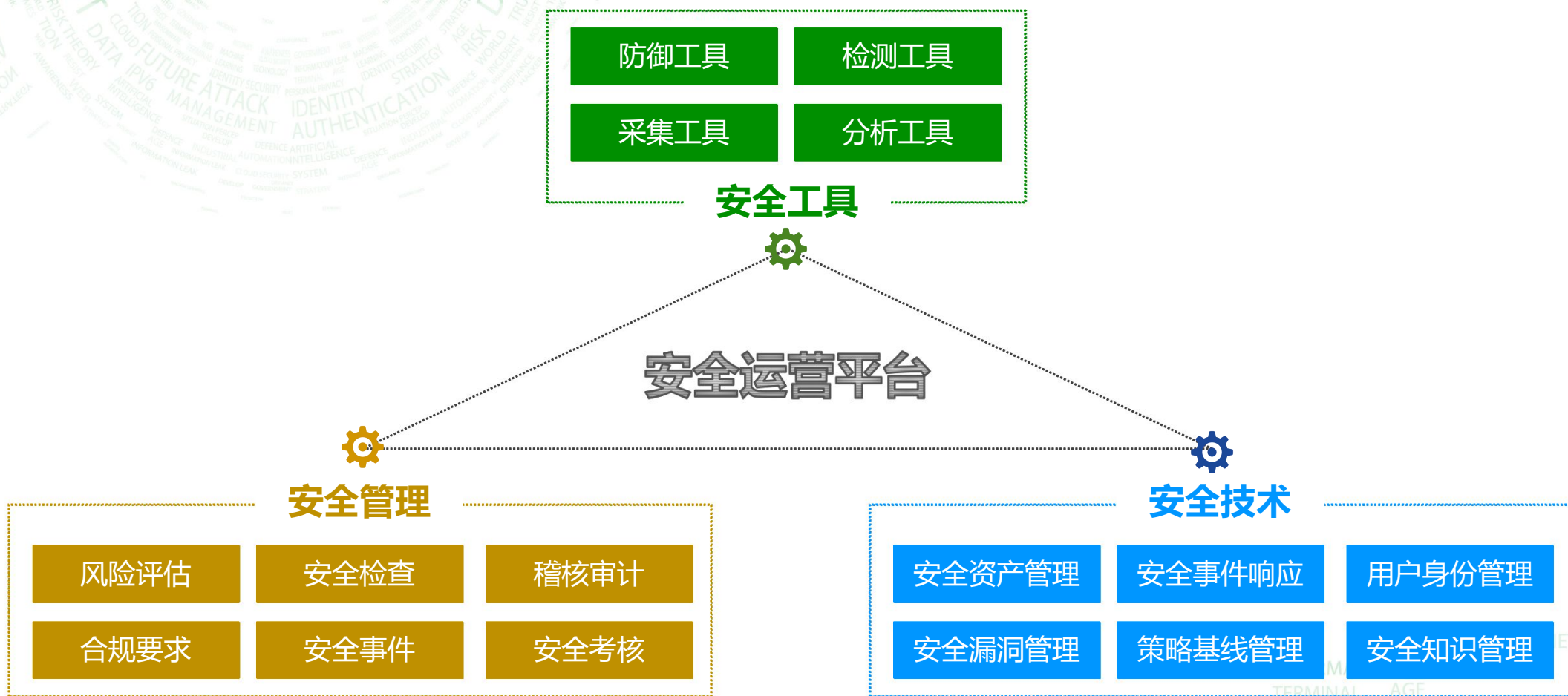
安全管理框架的转变



【新型自适应安全架构】

ZERO TRUST SECURITY

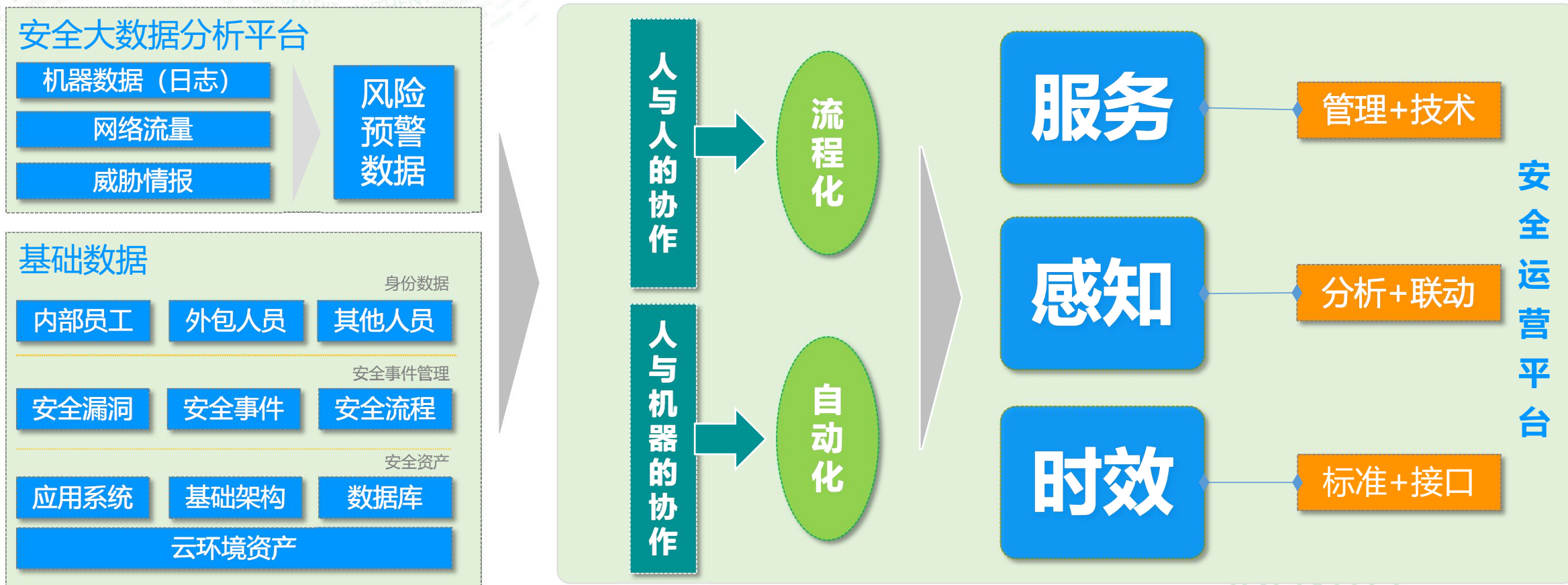
2.2 将安全视为一个整体，通过系统化的方式进行全面管理



2.3 重视安全运营，实现持续安全

以整体的运营保障持续的安全：

- 改变传统，以一切可管理、可量化、可分析为准则，实现自动化管理和持续的安全响应。



2.4 安全要自动化：流程的自动化、工具的自动化

以运营的理念，实现安全的自动化：

利用技术手段，实现安全开发测试、运维、以及安全风险检测、分析和响应的自动化，提升用户体验、风险检测、预警和处置效率。

安全运营

● 安全测试的自动化

- 安全测试工具资源自动化调度；
- 安全测试结果的自动解析和过滤；
- 安全漏洞的自动派发给指定处理人员；
- 安全漏洞修复进度和结果的自动跟踪。

● 安全运维的自动化

- 安全运维流程的自动化；
- 安全设备/系统配置的自动化。

● 安全响应的自动化

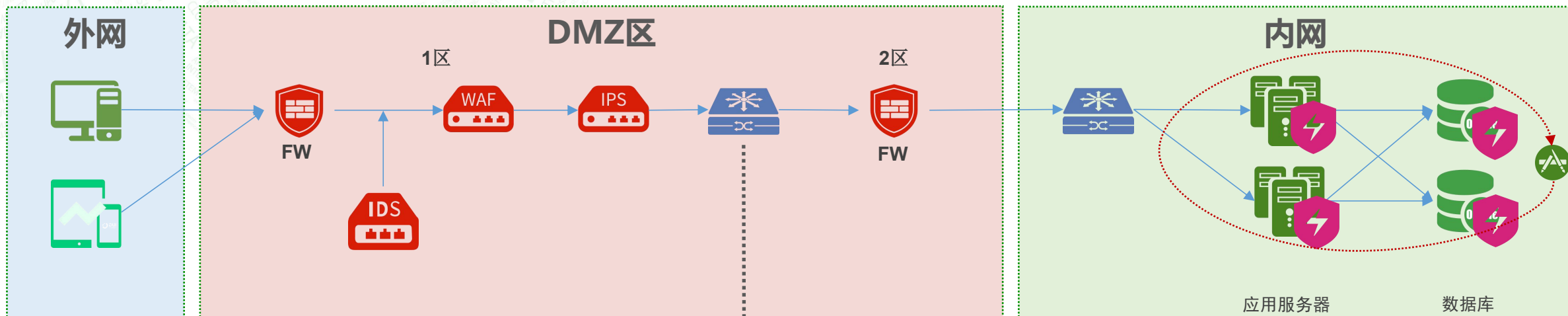
- 安全风险/事件分析预警的自动化；
- 安全攻击风险处置的自动化。

2.5 安全数字化、以数据说话



ZERO TRUST SECURITY

2.6 将注意力从网络层转移到应用层，更加贴近于业务



- **传统模式下**，网络防护手段主要集中在网络层面，包括网络防火墙、IDS、IPS、WAF等。存在以下弊端：

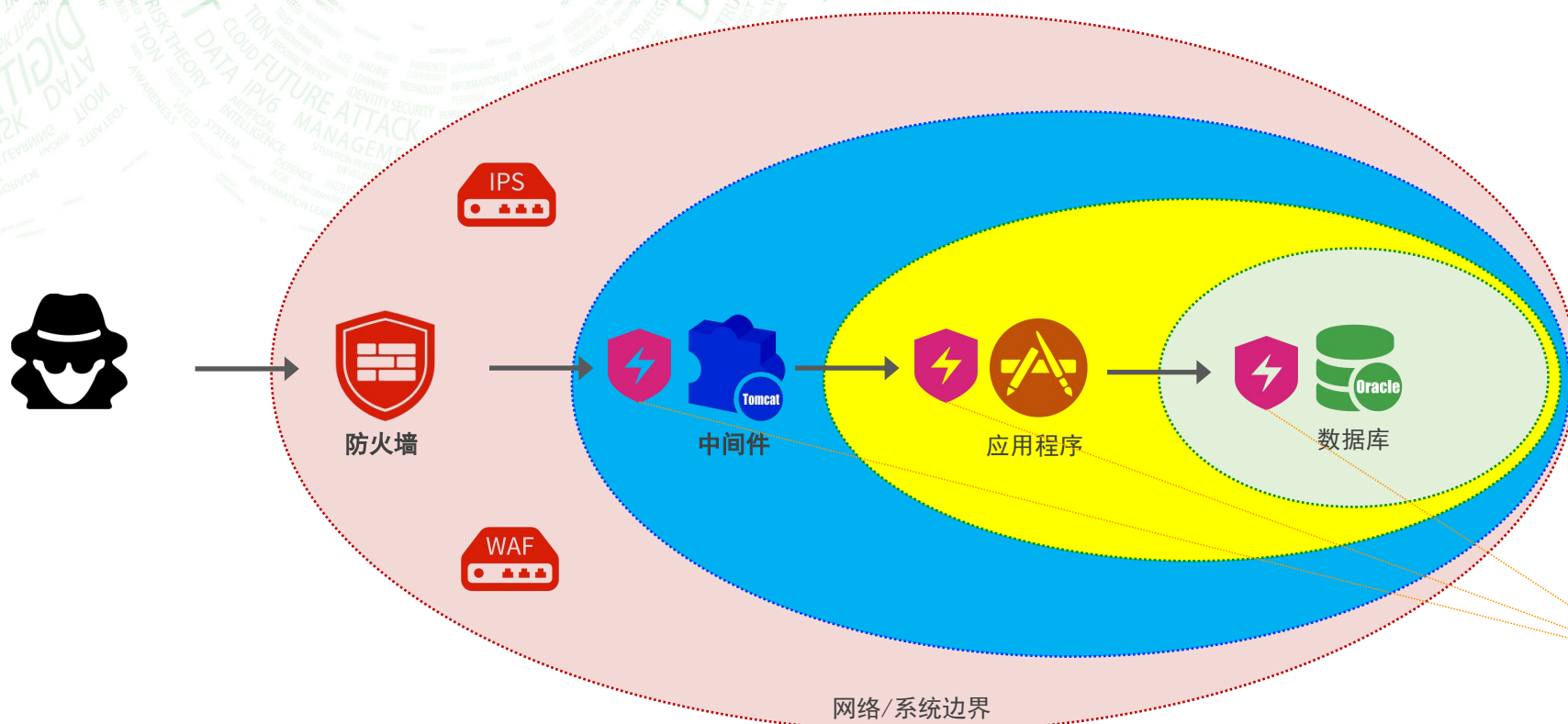
- 防护策略单一，不够灵活，无法根据业务特性进行适配；
- 一旦网络层面被突破，内网里的所有应用都将被暴露。

- **新形势下**，传统的网络架构和防御壁垒已经被打破，我们应该将安全注意力从网络层下沉到应用本身，充分贴近业务：

- 提升应用程序自身的安全防御能力；
- 根据应用业务特性（如用户、访问途径、数据等）进行个性化的安全防护，既能提高资源利用率，又能够避免安全风险的横向扩展。

ZERO TRUST SECURITY

2.7 不再游离于边界，而是要深入到应用系统内部，敢于埋点



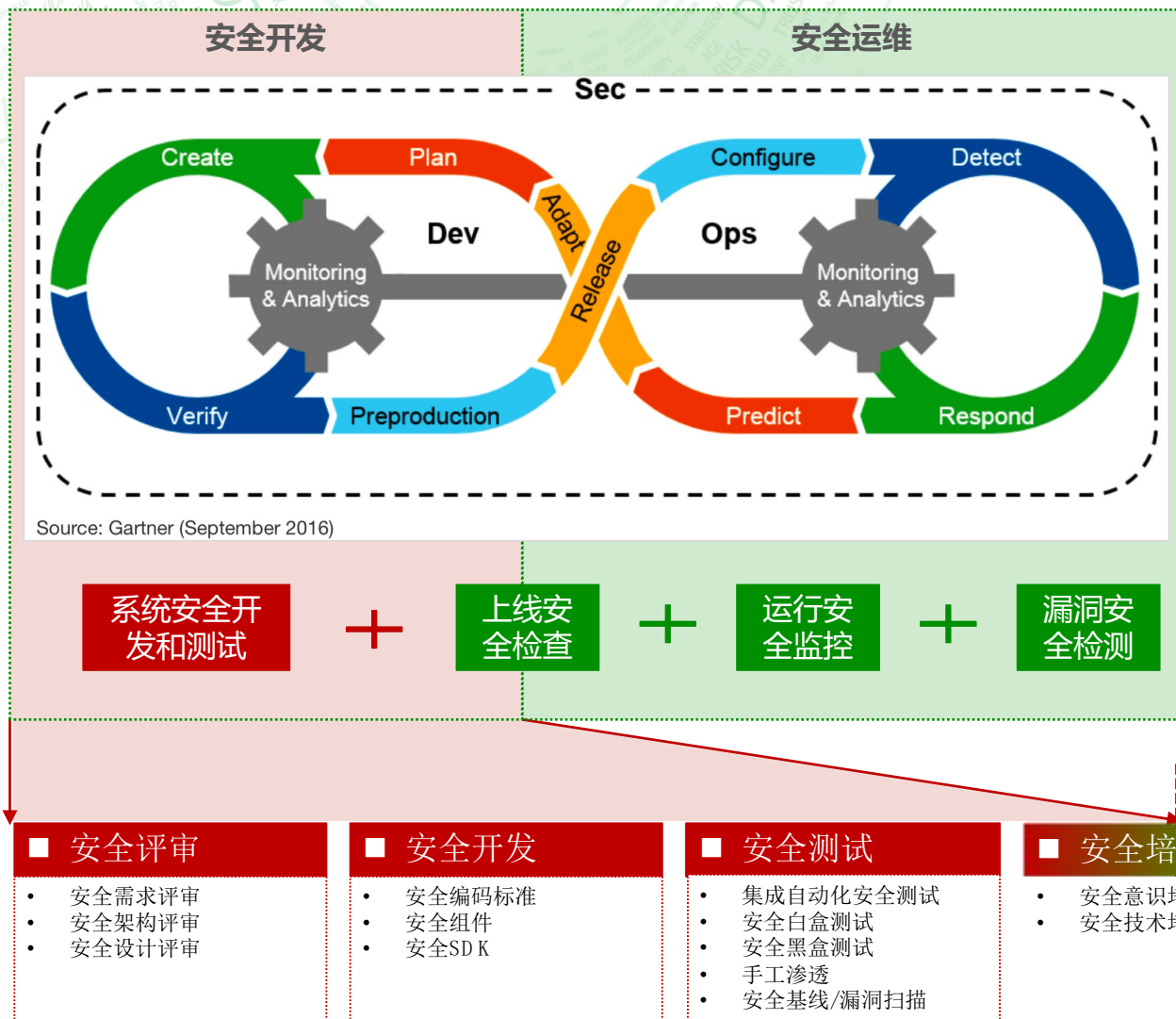
- **新形势下**，安全防御手段深入到系统内部将成为主流。
- 从应用系统层面加强安全攻击风险的监控和防御，结合安全大数据分析和威胁情报，进行安全风险感知、预警和响应。



随着云计算、移动互联进程的持续推进，
网络和系统的边界逐渐消失，传统意义上的防御手段将失效。

ZERO TRUST SECURITY

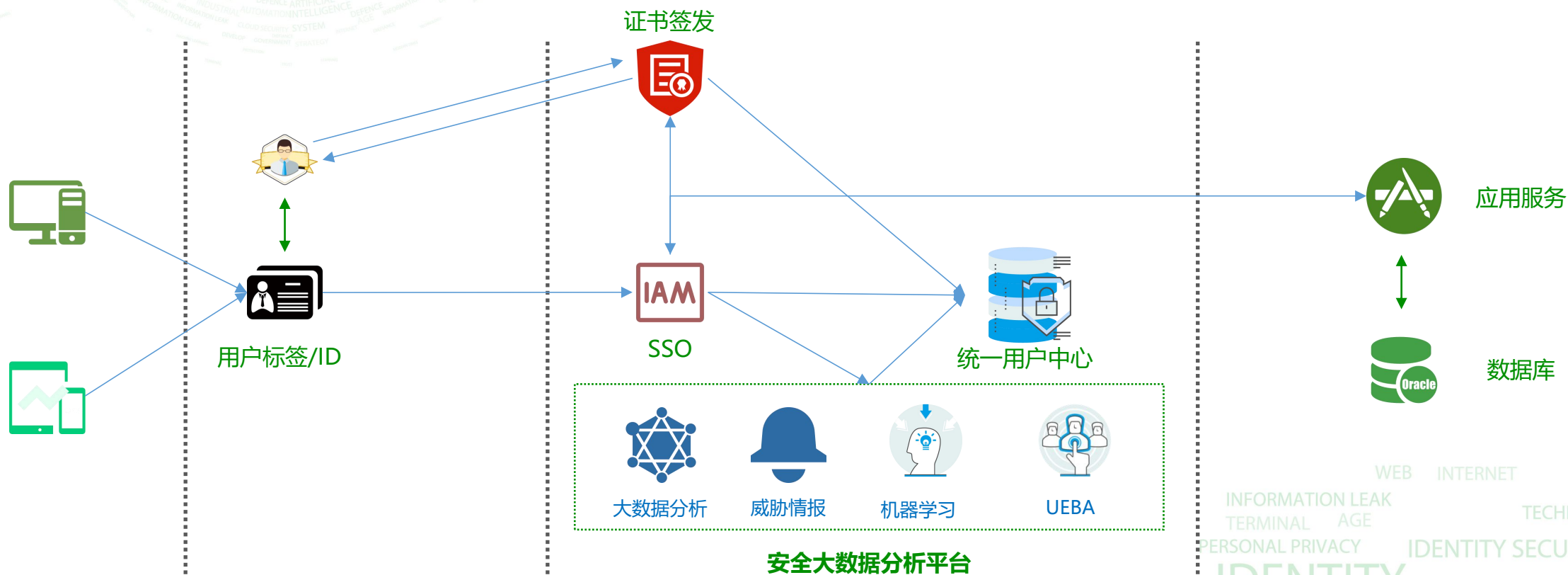
2.8 应用安全要左移，抓住主要矛盾和矛盾的主要方面



- **传统应用安全管理方法**中：对于应用系统的安全管理，更多是控制“带病”系统的上线，以及系统上线交付运维后的安全监控和漏洞检测。大量安全控制工作积压在系统上线阶段。
- 而当下，敏捷开发模式更能适应企业互联网业务对IT快速响应的要求，对应传统的应用安全管理方法已经无法跟上应用需求快速迭代的步伐。
- **新形势下：**应将应用安全控制工作左移，争取在系统开发阶段解决80-90%的安全问题。同时，将主要资源使用在核心的安全问题上，解决严重的安全漏洞和风险，并建立基线标准。

2.9 重视用户和实体的身份管理体系，构建安全的新边界

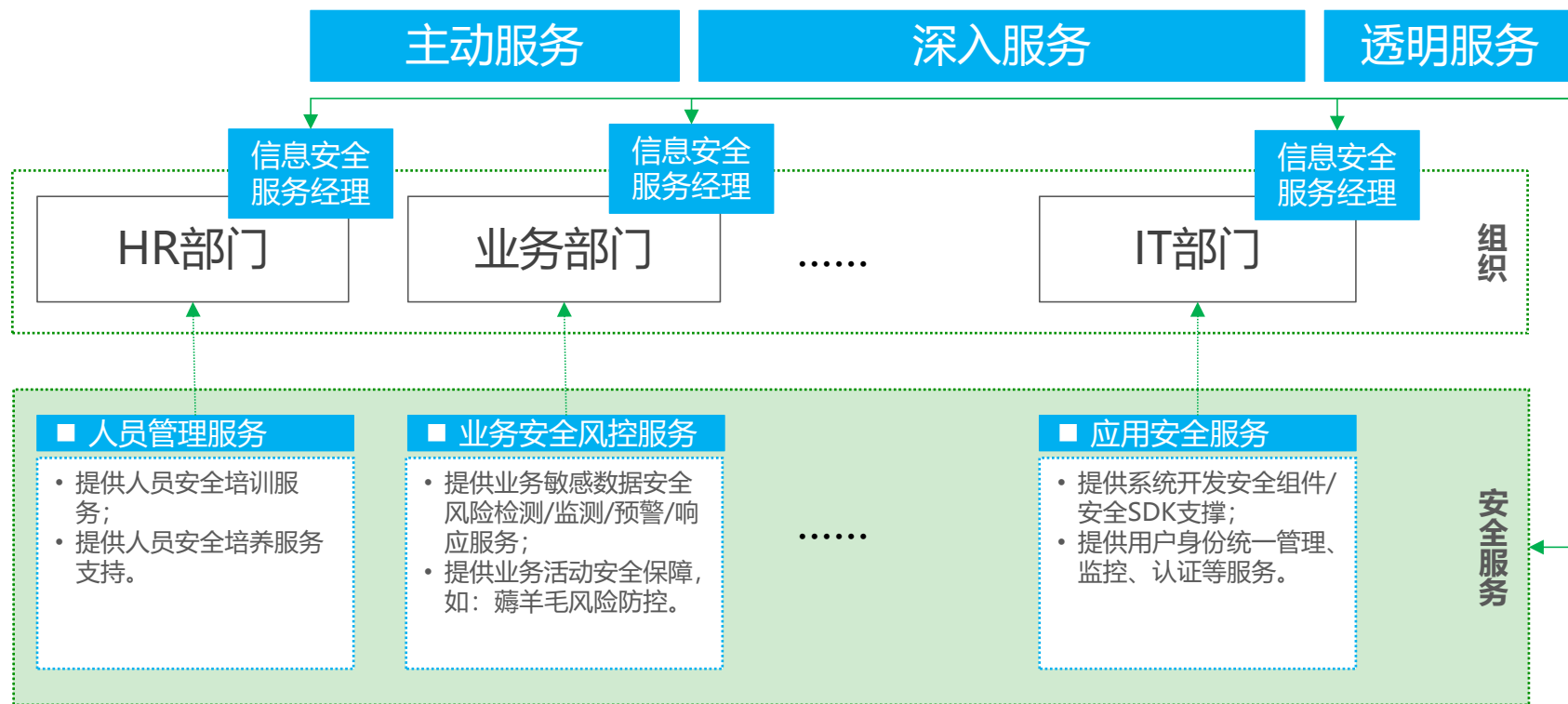
随着网络安全访问控制措施的下沉，对用户身份的标识、以及对用户实体行为的分析将至关重要。传统企业应该考虑建设企业统一的用户中心，完善用户和实体的身份管理体系，重构企业网络安全的新边界。



2.10 安全服务化、透明化

在新形势下，信息安全应秉承主动、深入、和透明服务的理念：

- 主动服务，使安全更接地气；
- 深入贴近业务，使安全能让业务和用户感受实实在在的好处；
- 提升安全技术能力/性能，确保不对业务和用户习惯带来负面影响。



信息安全

ZERO TRUST SECURITY

与我联系



ISC 互联网安全大会



360 互联网安全中心



扫描左侧二维码关注
我的微信公众号

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360互联网安全中心

谢谢!

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China